HIPAA / PHI DLP Pack — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — HIPAA / PHI DLP Pack (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 5

Boundaries (so scope is clear) . . . 5

1. Solution Overview — HIPAA / PHI DLP Pack (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 6

How it works . . . 6

The five DLP locations (and what each controls for PHI) . . . 7

The simulate→enforce journey (the core discipline) . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 8

2. Requirements — HIPAA / PHI DLP Pack (Microsoft Purview) 9

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP . . . 9

2.2 DLP-specific least-privilege roles . . . 9

2.3 Devices onboarded to Purview for Endpoint DLP . . . 10

2.4 A PHI classification intent and a HIPAA sensitive-information-type map . . . 10

2.5 Source data for Exact Data Match (only if EDM is used) . . . 11

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific) . . . 11

2.7 A PHI incident/alert triage owner, destination, and escalation to the Privacy/Security Officer . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 14

3. Implementation Guide — HIPAA / PHI DLP Pack (Microsoft Purview) 14

Phase 0 — Connect and baseline (Assess) . . . 15

Phase 1 — Design the PHI classification layer (SITs & classifiers) . . . 15

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact) . . . 16

Phase 3 — Measure and tune (drive PHI false positives down) . . . 17
Phase 4 — Enforce in a pilot ring (Pilot) . . . 18
Phase 5 — Expand and harden (Enforce → Operate) . . . 18
Order-of-operations summary . . . 19
5. Testing & Validation — HIPAA / PHI DLP Pack (Microsoft Purview) 19
Test A — Detection & enforcement (PHI leaks are blocked) . . . 20
Test B — False-positive rate (adoption gate) . . . 20
Test C — Incident / alert handling & escalation (the control is operable) . . . 21
Simulation-first & rollback validation . . . 22
Evidence to capture (for the HIPAA control record) . . . 22
6. Troubleshooting — HIPAA / PHI DLP Pack (Microsoft Purview) 23
Policy / PHI detection . . . 23
PHI over-matching (the adoption killer) . . . 24
Endpoint DLP . . . 24
Alerts / incident handling & escalation . . . 25
Connectivity / tooling . . . 25
7. Best Practices — HIPAA / PHI DLP Pack (Microsoft Purview) 26
Simulate before you enforce — always . . . 26
Tune for PHI, which is a combination — not a single token . . . 27
Right-size the user experience for a clinical audience . . . 27
Endpoint DLP specifics . . . 27
Classification hygiene . . . 27
Operations, evidence & governance (HIPAA-facing) . . . 28
Stay inside the boundary . . . 28
8. Deliverables Summary — HIPAA / PHI DLP Pack (Microsoft Purview) 28
Documentation . . . 29
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 29
Definition of done . . . 30
Appendix A — PowerShell Scripts 32

Executive Summary — HIPAA / PHI DLP Pack (Microsoft Purview)

The problem

Protected health information (PHI) leaves HIPAA-regulated organizations through the channels people use every day — an email to the wrong recipient, an "anyone with the link" cloud share, a member list pasted into Teams, or a discharge summary copied to a USB stick or printed. Without a working data-loss control, those disclosures are invisible until they become an incident — and, potentially, a reportable breach. The common failed attempt — switching data-loss controls straight to "block" — floods the help desk with false positives, breaks clinical and billing workflows, and gets turned off within a week.

The solution

Implement **Microsoft Purview Data Loss Prevention (DLP)** tuned for **PHI** across all five locations — **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. Detection is driven by the **HIPAA-relevant sensitive information types** Microsoft ships — including the built-in **"U.S. Health Insurance Act (HIPAA)"** template and its underlying SITs (SSN, ICD-9-CM, ICD-10-CM, DEA Number) — extended with **custom SITs / Exact Data Match** for your own medical record and member identifiers. The defining discipline is that **every policy is built and proven in SIMULATION first** (Microsoft's built-in test mode that shows what *would* be blocked, with zero user impact), tuned for a **low false-positive rate** using the fact that **PHI is a combination** (identifier + clinical detector), then enforced to a **pilot ring** — encrypting outbound PHI email rather than simply blocking — then expanded. The result: PHI leaks are controlled without breaking care.

What it delivers

- A mapped **PHI classification layer** — the right detector for each in-scope category, reusing the built-in HIPAA SITs and adding custom/EDM only for real gaps (your MRN, your member ID).
- **DLP policies across email, cloud, Teams, and endpoint**, each proven in simulation, tuned, and enforced through policy tips, user justification/override, encryption, or block.
- A **measured false-positive rate** kept at/under an agreed threshold — the difference between a control clinicians trust and one they ignore.
- An **incident/alert triage workflow with a Privacy/Security-Officer escalation path** so every potential PHI disclosure is acted on, with an evidence trail in Activity Explorer and optional SIEM forwarding.
- **Five PowerShell tools** (posture assessment, policy config helper, validation checker, match/false-positive report, scope/health helper) — read-only or `-WhatIf` by default, simulation-only where they write, no credentials in code.

Business outcomes

• **PHI leaks controlled** across the channels PHI actually walks out through — email, cloud sharing, and USB/print on endpoints — with outbound PHI email **encrypted**, not just blocked.

• **Minimal disruption** — simulation-first plus co-occurrence tuning means the control catches PHI without a wave of false positives, and any policy reverts to simulation instantly if needed.

• **Defensible and auditable** — matches raise alerts that are triaged to disposition and escalated appropriately, with evidence retained as the HIPAA control record.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and tooled to run in-house.

Boundaries (so scope is clear)

DLP is licensing-/plan-dependent — **Endpoint DLP and advanced classifiers require E5 / E5 Compliance and onboarded devices** (verify your tenant), and the HIPAA template/SIT library evolves. This solution provides the **technical configuration and the evidence**; *which* data is PHI, *which* classifiers legally apply, the **enforced action per category**, the **acceptable false-positive threshold**, and — decisively — **whether any event is a reportable HIPAA breach** are **compliance, privacy, and legal determinations**, captured alongside the delivered evidence.

1. Solution Overview — HIPAA / PHI DLP Pack (Microsoft Purview)

What this solution is

Protected health information (PHI) — a patient name or medical record number combined with a diagnosis, a claim, a lab result, or an insurance identifier — leaves organizations through the same everyday channels as any other data: an email to the wrong recipient, a "anyone with the link" cloud share, a spreadsheet of member records pasted into Teams, or a discharge summary copied to a USB stick or printed. For a HIPAA-regulated organization (a covered entity or business associate) that movement is both a **compliance gap** and a **breach exposure**.

This solution is a repeatable, evidence-driven way to implement **Microsoft Purview Data Loss Prevention (DLP)** tuned for **PHI** across **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party DLP tooling. Detection is driven by the **HIPAA-relevant sensitive information types (SITs)** Microsoft ships (see below), extended with **custom SITs / Exact Data Match** for your own identifiers (e.g. a medical record number format). Its defining discipline is that **every policy is built and proven in SIMULATION mode first** (Microsoft's built-in test mode that evaluates policy against real traffic and shows what *would* have matched, without affecting a single user), tuned for a low false-positive rate, and only then enforced.

> ***Scope boundary (read this first).*** *This solution delivers the **technical method and the evidence** for PHI-focused DLP. *Which* data is PHI in your environment, *which* HIPAA identifiers and classifiers legally apply, *what* the enforced action must be, retention of DLP evidence, and — above all —*

> ***whether a given event constitutes a reportable HIPAA breach*** *are* ***compliance, privacy, HIPAA-Security/Privacy-Officer, and legal determinations****, deferred to those functions. The solution helps you configure and prove the control; it does not make the regulatory determination.*

Why this matters

• PHI DLP switched straight to **enforce** without simulation is the classic failure: it blocks

legitimate clinical and billing workflows (referrals, claims, care coordination), floods the help desk, and gets disabled within a week. Simulation-first is the difference between a control that survives an OCR audit and one that was turned off.

• **PHI is a combination, not a single token.** A diagnosis code on its own, or a name on its own, is

often not PHI; the *pair* is. Microsoft's HIPAA detection reflects this — which is exactly why confidence, instance count, and supporting evidence tuning matters so much for PHI.

• **Endpoint DLP is licensing- and onboarding-dependent** — it requires the right plan and devices

onboarded to Purview (shared with Microsoft Defender for Endpoint onboarding). A DLP policy scoped to the Devices location does nothing until the endpoints are actually onboarded and reporting.

• A HIPAA control has to be **defensible**: an evidence trail (Activity Explorer, DLP alerts, an audit

export) that shows the control exists, what it caught, and how incidents were handled. This solution produces that evidence as a first-class deliverable.

How it works

1. **Sensitive information types (SITs) and classifiers** define *what* to look for. For PHI, Purview

ships a built-in **DLP policy template "U.S. Health Insurance Act (HIPAA)"** and the underlying built-in SITs it uses — including **U.S. Social Security Number (SSN)**, **International Classification of Diseases (ICD-9-CM)**, and **International Classification of Diseases (ICD-10-CM)** — plus related SITs such as **Drug Enforcement Agency (DEA) Number** and passport/ID SITs. You extend these with **custom SITs** (e.g. a medical record number / MRN regex + keyword + confidence), **Exact Data Match (EDM)** against a hashed upload of your patient roster for near-zero false positives, and **trainable classifiers** where a category is conceptual. *Confirm each SIT's availability in your tenant — the SIT library and templates evolve.*

1. **DLP policies** bind those SITs to **locations** (Exchange, SharePoint, OneDrive, Teams

chat/channel, and **Devices/Endpoint**) with **conditions** (which SIT, how many instances, what confidence), **actions** (audit / notify / restrict / block; encrypt outbound mail; restrict USB/print/cloud-upload on endpoint), and **user experience** (policy tips, allow-with-justification, allow-override).

1. **Simulation mode** runs the policy against live traffic and records what *would* have matched — with

or without policy tips shown — so you see the true PHI hit volume and false positives **before** any enforcement. Every policy in this solution starts here.

1. **Tuning** reduces false positives using confidence levels, instance thresholds, supporting keyword

evidence, EDM, and exceptions — measured against the simulation results.

1. **Enforcement** turns the tuned policy on (tips/override/block; encrypt PHI email) in a limited ring,

then expands.

1. **Incident/alert handling** — DLP rule matches raise **alerts** in the Purview portal and DLP events

flow to **Activity Explorer**; this solution wires triage, severity, and response so a possible PHI disclosure is actually reviewed (and escalated to the Privacy/Security Officer where the *breach* determination is made — deferred).

The five DLP locations (and what each controls for PHI)

- **Exchange (email):** outbound mail containing PHI matched on content, attachments, and recipients —

block, or **encrypt** on match to an external recipient.

- **SharePoint & OneDrive:** documents containing PHI at rest and when shared; block external sharing on

match.

- **Teams chat & channel messages:** PHI pasted or shared in messages (a common care-coordination leak).

- **Endpoint (Devices):** activities on **onboarded** Windows/macOS devices — copy PHI to USB, copy to

network share, print, upload to unallowed cloud apps/browsers, copy to clipboard, paste to browser. **Requires onboarding and the right licensing.**

- **On-premises / Fabric / Power BI / cloud apps (Defender for Cloud Apps):** additional locations that

may be available depending on licensing — **verify availability in your tenant.**

The simulate→enforce journey (the core discipline)

> *Map HIPAA SITs/classifiers → build each DLP policy in **SIMULATION** (no user impact) → measure PHI hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** (confidence, instance count, keywords, EDM, exceptions) → re-simulate until false positives are acceptable → enable with **policy tips + allow-override/justification** (and **encrypt** for outbound PHI email) in a **pilot ring** → validate → expand to enforcement tenant-wide → operate (triage alerts, review overrides, re-tune).*

What you can control

- Which HIPAA SITs/classifiers are in scope and at what **confidence** and **instance count** they

trigger.

- Which **locations** each policy covers and which users/sites/groups are **included or excluded**

(e.g. a clinical department pilot ring).

- The **action** per data category (audit → tip → justify → block → encrypt) — set per compliance's

determination.

- Whether users get **policy tips**, can **override** with justification, and what the override says.

- The **pilot ring** enforced first, and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

• **This is not a HIPAA breach determination tool.** DLP surfaces *potential* PHI disclosures; whether an event is a **reportable breach** (and any 60-day notification) is a Privacy/Security-Officer and legal decision — deferred.

• **Endpoint DLP requires onboarded devices and the appropriate licensing** (verify your plan — endpoint DLP and several advanced classifiers are gated behind E5 / the E5 Compliance add-on). A Devices-location policy is inert until onboarding is complete.

• **Some features are in preview** and portal paths / the SIT library **evolve** — this solution flags "verify your licensing/tenant" rather than asserting availability that may differ in your tenant.

• DLP inspects **content it can classify**; strongly encrypted or unrecognized formats, scanned images without OCR, or content below the confidence/instance threshold will not match. DLP is one control among several (labels, encryption, access), not a guarantee.

• **The enforced action and the acceptable false-positive threshold for PHI are compliance/legal decisions**, not technical defaults — this solution configures and proves the control; the determination is deferred.

Naming convention (used in every doc and script)

Every artifact this solution creates uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Custom sensitive info type (e.g. MRN)	`MRN – Custom SIT – PHI`
EDM schema / SIT (patient roster)	`Patient Identifiers – EDM – PHI`
Email DLP policy (simulation)	`DLP – PHI Email – Simulation`
Cloud DLP policy (simulation)	`DLP – PHI SPO+OneDrive+Teams – Simulation`
Endpoint DLP policy (simulation)	`DLP – PHI Endpoint – Simulation`
Enforced pilot policy	`DLP – PHI All Locations – Enforce Pilot`
Pilot user ring	`PHI DLP Pilot Ring – Stage1`
Policy-tip / override text	`PHI DLP Notice – Standard – AllPolicies`
Incident/alert workflow	`PHI DLP Alerts – Triage – Operations`

The standard deployment model

> ***Assess*** *current PHI exposure and classification intent →* ***Design*** *HIPAA SITs/classifiers, policies, and user experience →* ***Configure*** *SITs and policies* ***in simulation*** *→* ***Pilot*** *(simulate → tune → enforce to a ring) →* ***Validate*** *against pass/fail gates (PHI leaks blocked, false-positive rate low, incidents handled) →* ***Expand*** *to tenant-wide enforcement and ongoing operations. Every high-impact change is*

piloted in simulation first, with a documented rollback.

2. Requirements — HIPAA / PHI DLP Pack (Microsoft Purview)

These are the **solution-specific** prerequisites for implementing PHI-focused Purview DLP across endpoint, cloud, and email. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP

• **Description:** DLP for **Exchange/SharePoint/OneDrive/Teams** and **built-in SITs** (including the HIPAA-relevant SITs — SSN, ICD-9-CM, ICD-10-CM, DEA Number) is broadly available, but **Endpoint DLP**, **advanced/custom classifiers**, **Exact Data Match**, and **trainable classifiers** are **plan-gated** — typically **Microsoft 365 E5** or the **E5 Compliance** add-on (some capabilities are in **preview**). This extends GR-#1 with the DLP-specific plan detail.

• **Why required:** A DLP policy scoped to a location or using a classifier your plan doesn't include will not function. Endpoint DLP (a common PHI walk-out path via USB/print) in particular is an E5/E5-Compliance capability.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the **Purview portal** → **Data Loss Prevention** confirm the **Endpoint DLP** and **Devices** location and the classifier types you intend to use are visible. **Flag "verify your licensing/tenant"** — availability evolves.

• **How to implement if missing:** Acquire/assign the required licensing (E5 or E5 Compliance) before building endpoint or advanced-classifier policies; scope the initial rollout to features your plan covers (email + cloud built-in HIPAA SITs work broadly).

2.2 DLP-specific least-privilege roles

• **Description:** The **DLP role groups** in the Purview portal — **Compliance Administrator** or **Compliance Data Administrator** to create/manage DLP policies, **DLP Compliance Management** for policy management, **View-Only DLP Compliance Management** for read-only review, and the **Data Loss Prevention** role for alert/incident handling. Global Administrator only where genuinely required. Extends GR-#2. For PHI, separate policy authors from alert triagers so PHI evidence access is least-privilege.

• **Why required:** Purview enforces fine-grained role groups; DLP configuration and PHI-alert triage require the matching role, and least privilege keeps who-can-see-PHI-evidence small.

• **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (or Microsoft Purview

roles) — confirm your account's role-group membership includes the DLP roles you need.

• **How to implement if missing:** Assign the least-privilege DLP role group under change control;

separate policy authors from alert triagers where possible.

2.3 Devices onboarded to Purview for Endpoint DLP

• **Description:** Endpoint DLP monitors activities on **onboarded Windows 10/11 and macOS devices**.

Onboarding is done in **Purview portal** → **Settings** → **Device onboarding** (or via Intune / a script / Group Policy), and is **shared with Microsoft Defender for Endpoint onboarding** — devices already onboarded to Defender for Endpoint are onboarded for Endpoint DLP. Clinician laptops/workstations that handle PHI are the priority scope.

• **Why required:** A DLP policy scoped to the **Devices** location does nothing on a device that is not

onboarded and reporting. Onboarding is the hard prerequisite for any endpoint PHI control (USB/print).

• **How to verify: Purview portal** → **Settings** → **Device onboarding** → **Devices** shows onboarded

devices; confirm target devices appear and are reporting. On a device, confirm the onboarding state per Microsoft's documented method.

• **How to implement if missing:** Onboard devices via the Purview device-onboarding package, Intune, or

Group Policy; confirm the minimum OS build and any required Antimalware/AV state per Microsoft docs before scoping endpoint policies.

2.4 A PHI classification intent and a HIPAA sensitive-information-type map

• **Description:** A documented view of **what PHI you are protecting** (member/patient identifiers +

clinical/billing data — e.g. MRN, SSN, diagnosis/ICD codes, insurance/member IDs, DEA numbers) mapped to the **SITs/classifiers** that detect it — the built-in **HIPAA template SITs** where they fit, and **custom SITs / EDM / trainable classifiers** where they don't (e.g. your MRN format). Extends GR-#4.

• **Why required:** PHI DLP policies key off SITs; without knowing which identifiers matter and which

SIT detects each (at what confidence and instance count), policies are guesswork and generate false positives that kill adoption.

• **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** lists

built-in and custom SITs; confirm the HIPAA-relevant ones (SSN, ICD-9-CM, ICD-10-CM, DEA Number) exist and any custom ones you need are planned. Confirm the PHI categories with the data owners and Privacy Officer.

• **How to implement if missing:** Build the SIT map (this solution's Discovery script assesses HIPAA-

relevant built-in SIT coverage); plan custom SITs / EDM / trainable classifiers for identifiers not covered. **Which identifiers legally constitute PHI is a Privacy/compliance determination — deferred.**

2.5 Source data for Exact Data Match (only if EDM is used)

• **Description:** For **EDM** SITs, a **sensitive data table** (e.g. a patient/member roster export)

and a workstation with the **EDM Upload Agent** to hash and upload it — the raw data never leaves your control; only salted hashes are uploaded. Ideal for near-zero-FP matching of *your* patient identifiers.

• **Why required:** EDM matches against *your actual roster*, which is what drives PHI false positives

to near zero — but it requires the schema, the hashed upload, and a **refresh cadence** as the roster changes.

• **How to verify:** Confirm the source table, the EDM schema, the upload agent host, and a scheduled

refresh. **Purview portal** → **Data classification** → **Exact data matches** shows configured EDM schemas.

• **How to implement if missing:** Define the EDM schema and refresh process (deferred to the data owner

for *which* fields are in scope); if EDM is not in your plan or not needed, use custom SITs with confidence/keyword tuning instead. **Handle the roster export itself as PHI under your own controls.**

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific)

• **Description:** A named **pilot user/device ring** (e.g. one clinical or billing department), an

agreed **simulation dwell time** (how long each policy runs in simulation before enforcement — long enough to capture representative clinical/billing traffic), and the **change-control window** for moving simulation → enforce. Extends GR-#6.

• **Why required:** PHI DLP is high-impact; enforcing without a simulation baseline and a limited ring

is how DLP breaks clinical/billing workflows. The house model mandates **simulation first**, then a ring, then expand.

• **How to verify:** Confirm the pilot ring membership, that **simulation mode** is selected on each new

policy, and the approval path to enforce.

• **How to implement if missing:** Define the ring and dwell time and agree change control before

enabling any enforcement action.

2.7 A PHI incident/alert triage owner, destination, and escalation to the Privacy/Security Officer

• **Description:** A named owner (or queue) for **DLP alerts** raised in **Purview portal → Data loss

prevention → Alerts**, plus where DLP events are reviewed (**Activity Explorer**) and, optionally, where they are forwarded (SIEM/Microsoft Sentinel via the Office 365 Management Activity API / Defender connectors). Crucially, an** escalation path to the HIPAA Privacy/Security Officer** for any match that may be a reportable disclosure. Severity and response actions defined.

• **Why required:** A PHI DLP match with no one to triage it is not a control — and the **breach

determination is not a technical decision**. Alerts and Activity Explorer are where potential PHI disclosures surface; someone must own triage and escalate the *breach* question to Privacy/Security.

• **How to verify:** Confirm the triage owner/queue, the alert-severity scheme, the Privacy/Security escalation path, and any SIEM forwarding is configured.

• **How to implement if missing:** Assign the owner, define severity/response and the escalation to the Privacy/Security Officer, and (optionally) wire SIEM forwarding before enforcement generates real PHI alerts.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	DLP/Endpoint licensing (E5 / E5 Compliance; verify)	Endpoint & advanced classifiers available
2.2	DLP least-privilege roles	Author + triage roles assigned (authors ≠ triagers)
2.3	Devices onboarded to Purview	Endpoint PHI location functional
2.4	PHI classification intent + HIPAA SIT map	Policies key off correct PHI SITs
2.5	EDM source data + agent (if used)	Near-zero-FP matching on your roster
2.6	Pilot ring + simulation dwell + change control	Simulate-first enforced
2.7	PHI alert triage owner + Privacy/Security escalation	Matches acted on; breach question escalated

> ***Deferred to compliance/privacy/legal:*** *which data is PHI, which identifiers/classifiers legally apply, the enforced action per category, the acceptable false-positive threshold, DLP-evidence retention, and — decisively —* ***whether any event is a reportable HIPAA breach****. This solution provides the technical configuration and evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are*

*in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — HIPAA / PHI DLP Pack (Microsoft Purview)

This is the exact, ordered procedure to implement PHI-focused Purview DLP across **email, cloud, Teams, and endpoint** — every policy built in **SIMULATION** first, tuned, then enforced in a ring, then expanded. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan- dependent features, the evolving SIT library, and portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`) and* ***Microsoft Graph****. They are* ***read-only or*** *`-WhatIf` **by default**; writes require an explicit `-Commit` switch, and the config helper is* ***simulation-only*** *— it never creates or leaves a policy in enforce. No credentials are stored in code.*
>
> ***Determinations deferred.*** **Which* data is PHI, *which* HIPAA identifiers/classifiers legally apply, the *enforced action* per category, and whether any event is a* ***reportable breach*** *are compliance/privacy/legal decisions. This guide configures and proves the control; capture the in-scope-PHI and enforced-action decisions before Phase 4.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\PHIDLP-Discovery.ps1 -CsvPath .\PHIDLP-Posture.csv
```

It reports existing DLP policies and their mode, the presence of the **HIPAA-relevant built-in SITs** (SSN, ICD-9-CM, ICD-10-CM, DEA Number), custom-SIT coverage, and licensing/endpoint readiness signals.

1. **Confirm licensing and endpoint readiness** (Req 2.1, 2.3): confirm E5/E5-Compliance where endpoint

or advanced classifiers are needed, and that target clinician/billing devices are **onboarded** (script #5 checks this).

Pass/fail gate: you have a written baseline (existing policies + modes), a HIPAA-SIT coverage map, and confirmed licensing + endpoint onboarding for the locations you will target. **Rollback:** none (read-only).

Phase 1 — Design the PHI classification layer (SITs & classifiers)

Decide, per in-scope PHI category, which detector applies. Do **not** invent SITs — use the built-in HIPAA-relevant SITs where they fit; build custom/EDM/trainable only for gaps.

1. **Map the built-in HIPAA SITs first.** In **Purview portal → Data classification → Classifiers →

Sensitive info types**, confirm the built-in SITs the** "U.S. Health Insurance Act (HIPAA)" **DLP template uses and related PHI detectors:** U.S. Social Security Number (SSN)**,** International Classification of Diseases (ICD-9-CM)**,** International Classification of Diseases (ICD-10-CM)**, and** Drug Enforcement Agency (DEA) Number**. Note each SIT's** confidence levels **and default** instance count**. *Verify availability in your tenant — the SIT library evolves.*

1. **Author custom SITs for gaps** — most commonly your **medical record number (MRN)**. Create

`MRN – Custom SIT – PHI` with a **regex primary pattern** for your MRN format, **supporting keywords** (e.g. "MRN", "medical record", "patient ID"), a **confidence level**, and a **character proximity**. Portal: **Classifiers** → **Sensitive info types** → **Create sensitive info type**. Test it against sample (fake) text in the wizard's **Test** step.

1. **Configure EDM only where near-zero false positives are required** (Req 2.5). Define the schema

(`Patient Identifiers – EDM – PHI`), hash-and-upload the roster with the **EDM Upload Agent**, and set a **refresh cadence**. Portal: **Data classification** → **Exact data matches**. *Which fields are in scope is the data owner's/Privacy Officer's determination; handle the roster export as PHI.*

1. **Add trainable classifiers where a category is conceptual, not pattern-based** (e.g. a medical/health

trainable classifier if one is available for your plan) — verify availability against your plan before relying on it.

Pass/fail gate: every in-scope PHI category maps to a named, tested SIT/classifier at a chosen confidence and instance count. **Rollback:** delete unused custom SITs/EDM schemas (they have no effect until referenced by a policy).

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact)

Create **one policy per location group**, each in **simulation mode**. Simulation evaluates the policy against real traffic and records what *would* match, with **no** enforcement and (optionally) with policy tips shown. You can start from the built-in **"U.S. Health Insurance Act (HIPAA)"** template and adjust, or build custom policies with the SITs from Phase 1.

1. **Email DLP policy —** `DLP – PHI Email – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → **Medical and health records** → **U.S. Health Insurance Act (HIPAA)** template (or custom) → **Locations: Exchange email only** → rule: condition *Content contains* the PHI SITs from Phase 1 at the chosen confidence/instance count → action *Restrict access or encrypt* (kept inert by simulation; the enforced flavour will **encrypt** outbound PHI mail) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Finish.

1. **Cloud DLP policy —** `DLP – PHI SPO+OneDrive+Teams – Simulation`**.**

Same flow → **Locations: SharePoint sites, OneDrive accounts, Teams chat and channel messages** → conditions as above → action *Restrict access* (block external sharing on match) → **simulation mode**.

1. **Endpoint DLP policy —** `DLP – PHI Endpoint – Simulation` (requires onboarded devices + licensing).

Same flow → **Locations: Devices** → conditions as above → **endpoint activities to audit/restrict**: *copy to USB/removable media*, *copy to network share*, *print*, *upload to unallowed cloud apps/browser*, *copy to clipboard*, *paste to browser* → **simulation mode**. Confirm the Devices location is selectable (if not, revisit licensing/onboarding — Req 2.1/2.3).

1. **Set the user experience** consistently: define `PHI DLP Notice – Standard – AllPolicies` policy-tip

text (plain clinical/business language — *why* it was flagged and *what to do*) and enable **allow override with justification** where compliance permits — but note tips/overrides only *appear* once a policy is enforced; in simulation they are captured, not shown to end users unless "simulation with policy tips" is selected.

1. **Verify with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\PHIDLP-Config.ps1 -PolicyName 'DLP - PHI Email - Simulation' -Locations Exchange `
    -SensitiveTypes 'U.S. Social Security Number (SSN)','International Classification of Diseases (ICD
    -MinCount 1 -Confidence Medium -WhatIf
```

Run with `-Commit` only to apply an intended change; the script creates in **simulation** and never leaves a policy in enforce.

Pass/fail gate: all three policies exist and are confirmed in **simulation** (scripts #1/#3 report `Mode = TestWithNotifications / TestWithoutNotifications`), scoped to the correct locations and PHI SITs. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive PHI false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.6) to capture representative clinical/billing traffic.

1. **Review what matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities) show every simulated match with the file/message, the SIT, and the confidence. Export with the reporting script:

```
.\PHIDLP-Report.ps1 -Days 14 -CsvPath .\PHIDLP-Matches.csv
```

1. **Classify each match** as true positive or **false positive** and identify the false-positive

drivers (e.g. an **SSN** SIT firing on a 9-digit account number, or an **ICD** code matching an unrelated reference number).

1. **Tune** to reduce false positives without losing true positives — remember **PHI is a

combination**:

• Require **co-occurrence** — configure the rule so a match needs *both* an identifier (SSN/MRN) and

a clinical detector (ICD-9/ICD-10) present, not either alone.

• Raise the **confidence level** (e.g. medium → high) so only high-confidence matches count.

• Raise the **instance count** for bulk-leak focus (e.g. a roster export), while keeping a low count

where a single-record disclosure matters — tune per category with compliance.

• Add **supporting keywords / proximity** to custom SITs (MRN) so context is required.

• Introduce **EDM** for categories where pattern SITs over-match your identifiers.

• Add **exceptions** (e.g. a sanctioned claims-clearinghouse address) where justified.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets

the validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with true PHI positives still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the diff before `-Commit`).

Phase 4 — Enforce in a pilot ring (Pilot)

1. **Scope to the pilot ring.** Add `PHI DLP Pilot Ring – Stage1` (users — e.g. one clinical/billing

department) and pilot devices as the **included** scope on each policy (all other users/devices excluded for now). Use script #5 (`-WhatIf` then `-Commit`) or the portal.

1. **Move the ring to enforcement.** Change **Policy mode** from *simulation* to **Turn it on / Enforce**.

Start with **policy tips + allow-override (justification)** and **encrypt** (rather than hard block) for outbound PHI email, so the pilot can report false negatives/positives while retaining a business escape hatch.

1. **Confirm enforcement is live** for the ring only (script #1 reports mode `Enable` and the scoped

identities). Confirm end users in the ring now see the `PHI DLP Notice – Standard – AllPolicies` tip on a test match (use fake PHI — see Testing).

1. **Handle incidents.** Wire `PHI DLP Alerts – Triage – Operations`: assign the alert owner/queue

(Req 2.7), set severities, wire the **escalation to the Privacy/Security Officer** for possible reportable disclosures, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot alert end-to-end to prove the workflow.

Pass/fail gate: the pilot ring is enforced (tips shown, overrides captured, PHI mail encrypted), matches raise alerts, and the triage workflow produces a dispositioned incident with a Privacy/Security escalation path exercised. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand and harden (Enforce → Operate)

1. **Expand scope** from the ring to the full intended population once the pilot gate passes, keeping

documented exclusions.

1. **Escalate the action** per compliance's determination — e.g. move a category from *tip + override / encrypt* to **block** where required — one category/location at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review

user overrides (are people justifying legitimate care coordination or bypassing?), refresh **EDM** roster data on cadence, and re-tune as clinical/billing behavior changes.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail

evidence for the HIPAA control record.

Pass/fail gate: enforcement live across the intended scope with the compliance-mandated action per category; false-positive rate steady/low; alerts triaged and escalated on cadence; overrides reviewed. **Rollback:** any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; individual policies can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, confirm licensing/onboarding	Posture CSV	Baseline + HIPAA-SIT map + readiness	n/a (read-only)
1 Design	Map HIPAA SITs, build MRN/EDM, classifiers	Custom SIT / EDM schema	Every PHI category → tested detector	Delete unused SIT/EDM
2 Configure	Build 3 policies in **simulation**	Email/Cloud/Endpoint sim policies	All in simulation, correct scope	Delete sim policy
3 Tune	Measure + reduce PHI false positives (co-occurrence)	Matches CSV	FP rate ≤ threshold	Revert tuning change
4 Pilot	Enforce to ring, encrypt PHI mail, wire alerts + escalation	Pilot ring, alert triage	Ring enforced, incident dispositioned	Back to simulation
5 Expand	Broaden scope, escalate to block, operate	Enforced policies	Full-scope enforce, low FP, alerts triaged	Simulation / disable

5. Testing & Validation — HIPAA / PHI DLP Pack (Microsoft Purview)

Validate the PHI DLP implementation against explicit **pass/fail gates**. The three headline gates for this solution are: **(A) PHI leaks are blocked**, **(B) the false-positive rate is low**, and **(C) incidents are handled and escalated**. Run every test with **non-real, clearly-fake test data** — a made-up MRN, the Microsoft-documented test SSN pattern, and a random ICD-10 code applied to a fake patient — **never real PHI**, and record the evidence.

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the **pilot ring**. Endpoint tests require an **onboarded** device (Req 2.3). PHI matches best on a **combination** (identifier + clinical detector), so build test samples that pair a fake SSN/MRN with a fake ICD code.*

Test A — Detection & enforcement (PHI leaks are blocked)

#	Test	Steps	Pass condition
A1	Email PHI blocked/encrypted	From a pilot-ring user, send an email to an **external** recipient containing a fake SSN/MRN paired with a fake ICD-10 code.	Message is blocked or **encrypted** per the enforced action; sender sees the policy tip; a DLP alert is raised.
A2	SharePoint/OneDrive external share blocked	As a ring user, upload a file with the fake PHI combination and attempt to share it **externally**.	External sharing is blocked/restricted on match; event appears in Activity Explorer.
A3	Teams message match	Paste the fake PHI combination into a Teams chat/channel covered by the policy.	Message is blocked or tipped per the enforced action; event logged.
A4	Endpoint — USB copy	On an onboarded ring device, copy a file containing the fake PHI to **removable media**.	Activity is audited/blocked per policy; endpoint DLP event appears in Activity Explorer.
A5	Endpoint — print / cloud upload	On the ring device, attempt to **print** the file and **upload** it to an unallowed cloud app/browser.	Each activity is audited/restricted per policy; events logged.
A6	Below-threshold / single-detector negative	Send content with only a lone ICD code or a lone 9-digit number (no pairing), below the threshold.	Correctly **not** matched (if co-occurrence is required) — confirms tuning holds and avoids false positives.

Gate A (pass): A1–A5 each produce the enforced action and a logged event; A6 correctly does not match (validating the PHI co-occurrence/threshold tuning).

Test B — False-positive rate (adoption gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time, export simulation matches (`PHIDLP-Report.ps1 -Days <n>`) and classify each as TP/FP.	**False-positive rate** ≤ **the agreed threshold** (define with compliance; a common target is ≤10% of matches, or an absolute FP count the triage team can absorb).

#	Test	Steps	Pass condition
B2	Legitimate-traffic negative	Run representative legitimate business content (no real PHI) — e.g. internal reference numbers, order IDs — through the covered channels.	Legitimate traffic is **not** matched — no spurious tips/blocks on non-PHI numbers.
B3	Post-tuning re-measure	After each tuning change (co-occurrence, confidence↑, instance count↑, keywords, EDM, exceptions), re-simulate and re-measure.	FP rate trends **down** while true PHI positives (Test A) still fire.
B4	Override sanity	In the pilot ring, review captured **allow-with-justification** overrides.	Overrides are legitimate clinical/billing justifications, not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with true PHI positives intact.

Test C — Incident / alert handling & escalation (the control is operable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a policy match (Test A1/A4).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.
C2	Triage workflow	The `PHI DLP Alerts – Triage – Operations` owner/queue picks up the alert, sets status, and dispositions it.	Alert moves through the defined states to a resolved disposition by the named owner.
C3	Privacy/Security escalation	For a match that *could* be a reportable disclosure, exercise the escalation path to the HIPAA Privacy/Security Officer.	The escalation path works and is documented; the **breach determination is made by Privacy/Security/legal, not the DLP tool**.

#	Test	Steps	Pass condition
C4	Activity Explorer trail	Locate the same event in **Data classification** → **Activity explorer**.	Full evidence trail present (user, location, SIT, action) for investigation.
C5	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.7).	Event present in the downstream system with usable fields.

Gate C (pass): matches raise alerts, alerts are triaged to disposition by the owner, the Privacy/Security escalation path is exercised, and the evidence trail (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `PHI DLP Pilot Ring – Stage1` experience no blocking during pilot.
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-blocked action now only simulates).
S3	Scripts are safe-by-default	`PHIDLP-Config.ps1` run **without** `-Commit` makes no change (`-WhatIf` output only) and is simulation-only; discovery/validate/report scripts are read-only; the scope/health helper writes only with `-Commit`.
S4	Validate gate check	`PHIDLP-Validate.ps1` reports each expected policy's mode, PHI-SIT presence, and scope — a green pass before enforcement, and the enforced state after.

Evidence to capture (for the HIPAA control record)

- Baseline posture CSV (Phase 0) and the HIPAA-SIT coverage map.
- Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).
- Screenshots/log of Test A enforcement/encryption actions and the raised alerts (Gate A/C).

• The dispositioned incident from Test C2, the **Privacy/Security escalation** evidence from C3, and, if used, the SIEM forward (C5).

• Confirmation that outside-ring users were unaffected (S1) and that simulation rollback works (S2).

• The `PHIDLP-Validate.ps1` output showing the expected policy/mode/SIT/scope state (S4).

> ***Determination boundary.*** *These tests prove the **control works**. Whether a given category's enforced action and FP threshold are *acceptable*, and whether any real event is a **reportable HIPAA breach**, are compliance/privacy/legal sign-offs, captured alongside the evidence above.*

6. Troubleshooting — HIPAA / PHI DLP Pack (Microsoft Purview)

Symptom-first fixes for the failures you actually hit implementing PHI DLP across email, cloud, Teams, and endpoint. Most problems are one of: a policy not matching PHI, PHI *over*-matching (false positives), the endpoint location unavailable, or matches that raise no alert / no escalation.

Policy / PHI detection

A PHI DLP policy matches nothing even though the content clearly contains PHI.

• Confirm the policy is actually **enabled and in a mode that evaluates** — a *disabled* policy does nothing; a **simulation** policy evaluates and logs but does not block. Check with `PHIDLP-Discovery.ps1` / `PHIDLP-Validate.ps1` (Mode column).

• **PHI often needs a combination.** If the rule requires *both* an identifier (SSN/MRN) **and** a clinical detector (ICD-9/ICD-10) and your test has only one, it correctly won't fire. Test with a paired sample, or relax the co-occurrence for the test.

• Check the **instance count and confidence** on the rule — if it requires high confidence / multiple instances and your sample is a single low-confidence hit, it won't match. Adjust for testing.

• **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (and longer for some locations)** to take effect. Wait before concluding it's broken.

• Confirm the **location scope** includes where you're testing (the specific site/user), and that the test identity isn't in an **exclusion**.

The custom MRN SIT never matches.

• Test the SIT's **regex + keywords** in the SIT wizard's **Test** step with a known-matching (fake) MRN. A too-strict regex, wrong **character proximity**, or a required keyword ("MRN"/"medical record") that isn't present will suppress all matches. Loosen and re-test incrementally.

The built-in HIPAA template / a HIPAA SIT isn't available.

• The template lives under **Data loss prevention → Create policy → Medical and health records → U.S.

Health Insurance Act (HIPAA) **— but the** SIT library and templates evolve and are licensing- dependent**. If it's absent,** verify your licensing/tenant **and build a custom policy with the available SITs (SSN, ICD-9-CM, ICD-10-CM, DEA Number) instead. Don't assume a named SIT exists — confirm it in** Data classification → Classifiers → Sensitive info types**.

Matches appear in simulation but nothing is blocked/encrypted.

• That is **correct** — simulation logs what *would* happen without enforcing. To block/encrypt, move the policy to **enforce** for the pilot ring (Implementation Phase 4). If you expected action, you're still in simulation.

PHI over-matching (the adoption killer)

Clinicians are getting policy tips on legitimate, non-PHI content (account numbers, order IDs).

• Export matches with `PHIDLP-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver.

• **Require co-occurrence** (identifier + clinical detector) so a lone 9-digit number or a lone ICD code doesn't fire — this removes the biggest PHI false-positive source.

• **Raise confidence** (medium→high) and/or **instance count** so single/low-confidence hits don't fire.

• Add **supporting keywords/proximity** to the custom MRN SIT so context is required.

• For a built-in SIT that over-matches your internal identifiers, move that category to **Exact Data Match** against your roster so only your real identifiers match.

• Add a targeted **exception** where justified (e.g. a sanctioned claims clearinghouse address) — narrowly, with a documented reason.

• Re-simulate after each change and re-measure — don't stack multiple changes blind.

Endpoint DLP

The Devices/Endpoint location isn't available when creating a policy.

• **Licensing:** Endpoint DLP requires the appropriate plan (E5 / E5 Compliance) — run `PHIDLP-ScopeHealth.ps1` for the licensing signal and **verify in the admin center**.

• **Onboarding:** the Devices location depends on **onboarded devices** — confirm in **Purview portal → Settings → Device onboarding**. No onboarded devices → the location does nothing even if selectable.

Endpoint policy is enforced but device activities (USB/print/upload) aren't caught.

• Confirm the specific **device is onboarded and reporting** (portal device list), meets the **minimum OS build**, and — for some activities — that the required agent/AV prerequisites per Microsoft docs are met.

• Confirm the **activity is in scope** of the rule (e.g. "copy to USB" is enabled) and that the app/browser or network path isn't on an **allowed/exception** list.

• Allow for **reporting latency** — endpoint events can take time to surface in Activity Explorer.

Alerts / incident handling & escalation

PHI matches occur but no alert appears / no one is notified.

• Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.

• Confirm **audit logging is enabled** in the tenant — the report script and Activity Explorer rely on it.

• Confirm the **triage owner/queue** (`PHI DLP Alerts – Triage – Operations`) exists and that the

Privacy/Security-Officer escalation path is wired (Req 2.7). If forwarding to SIEM/Sentinel, confirm the connector is healthy.

A possible reportable disclosure was found — what does the tool decide?

• **Nothing.** The DLP tool surfaces and evidences a *potential* PHI disclosure; the **breach determination (and any notification) is a Privacy/Security-Officer and legal decision** — escalate via the C3 path, don't treat a DLP alert as a breach ruling.

The report script returns no matches.

• **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run.

• Freshly created policies need **dwell time** — there may simply be no matches yet.

• Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

• Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth / MFA-capable** admin.

• Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

• The delivered scripts are **read-only or `-WhatIf` by default**; writes require `-Commit`, and the config helper is **simulation-only**. If a change landed, it was committed intentionally — the config helper never leaves a policy in **enforce**, so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
PHI policy matches nothing	Mode (disabled/sim), **co-occurrence** requirement, instance count/confidence, propagation, scope/exclusion
Custom MRN SIT never fires	Test regex+keywords+proximity in the SIT wizard
HIPAA template/SIT missing	Licensing/tenant; build custom with SSN/ICD-9/ICD-10/DEA instead
Nothing blocked/encrypted	Still in **simulation** — that's expected; enforce the ring to act
Too many false positives	Require co-occurrence, raise confidence/instance count, add keywords/EDM, exceptions, re-simulate
Devices location missing	Licensing (E5/E5 Compliance) + device **onboarding**
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed-app/network exceptions
No alert on match	Alert config on rule, audit logging on, triage owner + Privacy/Security escalation, SIEM connector
"Is this a breach?"	Not a DLP decision — **escalate to Privacy/Security/legal**
Report returns nothing	Audit latency/dwell time, audit logging on, role
Cmdlet/connect fails	Module updated, modern auth, correct DLP role

7. Best Practices — HIPAA / PHI DLP Pack (Microsoft Purview)

Field-tested practices for running PHI-focused Purview DLP across endpoint, cloud, and email so the control stays trusted, effective, low-noise, and defensible. These complement the Implementation and Testing guides.

Simulate before you enforce — always

• **Never** switch a new or materially changed PHI DLP policy straight to enforce. Run it in **simulation** first, long enough to capture representative clinical/billing traffic (Req 2.6), and read the results before enabling.

• Use **simulation with policy tips** on the pilot ring when you want end-user feedback before hard block or encrypt.

• Treat **simulation mode as your permanent safety switch**: any enforced policy can be returned to simulation in one setting, instantly removing enforcement with no data change — this is your rollback.

Tune for PHI, which is a combination — not a single token

- **Require co-occurrence** where it fits: match on an identifier (SSN/MRN) *and* a clinical detector (ICD-9/ICD-10) together, so a lone account number or a lone diagnosis code doesn't fire. This single change removes the largest source of PHI false positives.
- Start at **higher confidence** and a **realistic instance count** for bulk-leak detection (a roster export), but keep a **low count where a single-record disclosure matters** — tune per category with compliance, don't apply one threshold blindly.
- Use **Exact Data Match** against your patient/member roster for categories where pattern SITs over-fire — it matches your *actual* identifiers and drives false positives toward zero, at the cost of an upload + refresh cadence.
- Every false positive that reaches a clinician erodes trust in **every** policy tip. Budget for a tuning cycle, not a one-time build.

Right-size the user experience for a clinical audience

- Show **clear, actionable policy tips** in plain clinical/business language — tell the user *why* it was flagged and *what to do* (use secure send / encrypt), not a compliance error code. Reuse one standard notice (`PHI DLP Notice – Standard – AllPolicies`).
- Prefer **encrypt** (for outbound PHI email) and **allow-with-justification / override** over hard block for categories where legitimate care coordination exists, then **review the overrides** — routine overriding means the policy is mis-scoped.
- Reserve **hard block** for the categories where compliance/legal require it; escalate to block one category at a time, re-validating each.

Endpoint DLP specifics

- **Onboarding is the gate.** A Devices policy is inert until the device is onboarded (shared with Defender for Endpoint) and reporting — verify onboarding before blaming the policy. Prioritize clinician/billing workstations that handle PHI.
- Roll endpoint controls out **audit-first**: audit USB/print/cloud-upload activities before restricting, so you see real clinical usage patterns and avoid blocking legitimate workflows.
- Mind **unallowed vs allowed apps/browsers and network exceptions** — allow sanctioned clinical/billing tools and network paths so they aren't caught alongside exfiltration paths.

Classification hygiene

- **Reuse the built-in HIPAA SITs** (SSN, ICD-9-CM, ICD-10-CM, DEA Number) wherever they fit; build

custom/EDM/trainable only for genuine gaps (your MRN format, your member-ID format) — fewer, well-tuned detectors beat a sprawl of overlapping ones.

- **Version and document** each custom SIT/EDM schema (pattern, confidence, keywords, owner) so tuning

changes are traceable for an audit.

- **Refresh EDM roster data** on a schedule — a stale roster silently degrades matching. Handle the

roster export itself as PHI.

Operations, evidence & governance (HIPAA-facing)

- Give PHI DLP **alerts an owner and an SLA** (Req 2.7), and a **standing escalation to the

Privacy/Security Officer **for possible reportable disclosures. Match volume without triage is not a control — and the** breach determination is not a technical decision**.

- **Retain the evidence** the control produces (policy config, simulation FP measurement, alerts,

dispositioned incidents) as your HIPAA control record — retention period is a records/compliance determination.

- Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as

clinical and billing behavior drift.

- Enforce **least-privilege roles** and **separate policy authors from alert triagers** so PHI-evidence

access stays minimal.

- Keep a **change log** of every simulate→enforce transition and every action escalation, with the

compliance sign-off attached.

Stay inside the boundary

- DLP is **one control**, not a guarantee — it inspects content it can classify (not scanned images

without OCR, not strongly encrypted blobs); combine with **sensitivity labels, encryption, access controls, and insider-risk** where the PHI risk warrants.

- **Verify licensing/tenant** before relying on any endpoint or advanced-classifier capability, and

confirm the **HIPAA template and its SITs** exist in your tenant — plans, the SIT library, and portal paths evolve; don't assume a feature is present.

- The **enforced action, the acceptable false-positive threshold, which data is PHI, and whether any

event is a reportable HIPAA breach are compliance/privacy/legal determinations** — you provide the technical control and the evidence; they own the decision.

8. Deliverables Summary — HIPAA / PHI DLP Pack (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The PHI DLP model — HIPAA-relevant SITs/classifiers, the five locations (email, SharePoint, OneDrive, Teams, endpoint), policy tips/overrides/encryption, and the simulate→enforce journey; naming convention; and the clear boundary that breach determination is deferred.
Requirements Guide	Solution-specific prerequisites (DLP/Endpoint licensing, DLP roles, device onboarding, PHI classification intent + HIPAA SIT map, EDM source data, pilot ring, alert triage owner + Privacy/Security escalation) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → design HIPAA SITs (+ MRN/EDM) → build policies **in simulation** → tune PHI false positives (co-occurrence) → enforce to a pilot ring (encrypt PHI mail) → expand; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — PHI leaks blocked (A), low false-positive rate (B), incidents handled + escalated (C) — plus simulation-first and rollback checks, all with fake PHI test data.
Troubleshooting Guide	The common failure modes (policy not matching, PHI over-matching, endpoint location missing, no alerts) and how to resolve them.
Best Practices	Simulate-first discipline, PHI-as-a-combination tuning, clinical-audience UX, endpoint specifics, classification hygiene, and HIPAA-facing operations/evidence/governance.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`, and the config helper is **simulation-only** (it never leaves a policy in enforce). No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**PHIDLP-Discovery.ps1**	DLP posture + HIPAA-SIT coverage assessment: existing policies and their mode, presence of the HIPAA-relevant built-in SITs (SSN, ICD-9-CM, ICD-10-CM, DEA Number), custom-SIT coverage, licensing/endpoint readiness signals.	Read-only
2	**PHIDLP-Config.ps1**	PHI DLP policy configuration/remediation helper: creates/updates a policy **in simulation mode** with the chosen PHI SITs and reports the intended change.	`-WhatIf` (writes need `-Commit`; simulation-only, never enforce)
3	**PHIDLP-Validate.ps1**	Validation checker: for each expected policy, reports mode (simulation vs enforce), whether the PHI SITs are attached, and the location scope — the pass/fail gate before and after enforcement.	Read-only
4	**PHIDLP-Report.ps1**	PHI DLP match / false-positive tuning report: exports simulation/enforcement matches for TP-vs-FP classification and rate calculation.	Read-only
5	**PHIDLP-ScopeHealth.ps1**	Scope/health helper: reports a policy's included/excluded scope plus endpoint/licensing health signals, and (with `-Commit`) sets the pilot-ring scope.	`-WhatIf` (writes need `-Commit`)

Definition of done

• HIPAA-relevant SITs/classifiers mapped for every in-scope PHI category (built-in HIPAA SITs reused; custom MRN / EDM / trainable only for gaps).

• Email, cloud (SPO/OneDrive/Teams), and endpoint PHI DLP policies built and **proven in simulation**.

• False-positive rate measured and tuned (with **co-occurrence** where it fits) to at/under the agreed threshold (Gate B).

• Enforcement live for the pilot ring with policy tips + override + **encryption of outbound PHI email**, then expanded per compliance's action determination (Gate A).

• DLP alerts raised, triaged to disposition, **escalated to the Privacy/Security Officer** where a disclosure may be reportable, and evidence trailed in Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified (`PHIDLP-Validate.ps1` green); change log and compliance sign-offs captured as the HIPAA control record.

> ***Boundary:*** *the solution delivers the technical control and the evidence. The* ***data that is PHI, the classifiers that legally apply, the enforced action per category, the acceptable false-positive threshold, evidence retention, and whether any event is a reportable HIPAA breach*** *are compliance/privacy/legal determinations, captured alongside the evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PHIDLP-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule for one or more HIPAA-relevant sensitive information types) in SIMULATION mode, or updates an existing policy's rule, across the chosen locations (Exchange / SharePoint / OneDrive / Teams / Endpoint). Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement (and the encrypt/block action decision for PHI) is a deliberate, separate portal/change-control step. Optionally set -RequireAllTypes to require CO-OCCURRENCE of the supplied SITs (e.g. an identifier AND a clinical detector), which is the single biggest PHI false-positive reducer. HOW TO RUN Preview a PHI email simulation policy requiring SSN + an ICD code together: powershell -File .\PHIDLP-Config.ps1 -PolicyName 'DLP - PHI Email - Simulation' `-Locations Exchange` -SensitiveTypes 'U.S. Social Security Number (SSN)','International Classification of Diseases (ICD-10-CM)' `-RequireAllTypes -MinCount 1 -Confidence Medium -WhatIf Actually create it (still simulation mode): powershell -File .\PHIDLP-Config.ps1 -PolicyName 'DLP - PHI Email - Simulation'` -Locations Exchange `-SensitiveTypes 'U.S. Social Security Number (SSN)','International Classification of Diseases (ICD-10-CM)'` -RequireAllTypes -MinCount 1 -Confidence Medium -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with PHIDLP-Validate.ps1 / PHIDLP-Discovery.ps1. .NOTES Purview — HIPAA / PHI DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. Which data is PHI and the enforced action per category are compliance/privacy/legal determinations — deferred. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Default set = HIPAA-relevant built-in SITs. Verify these names exist in your tenant (SIT library evolves). [string[]]$SensitiveTypes = @('U.S. Social Security Number (SSN)','International Classification of Diseases (ICD-10-CM)'), Require ALL supplied SITs to co-occur (PHI = identifier + clinical detector). Off = ANY-of (a match on one). [switch]$RequireAllTypes, [int]$MinCount = 1, [ValidateSet('Low','Medium','High')][string]$Confidence = 'Medium', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview a PHI email simulation policy requiring SSN + an ICD code together: powershell -File .\PHIDLP-Config.ps1 -PolicyName 'DLP - PHI Email - Simulation' `-Locations Exchange` -SensitiveTypes 'U.S. Social Security Number (SSN)','International Classification of Diseases (ICD-10-CM)' `-RequireAllTypes -MinCount 1 -Confidence Medium -WhatIf Actually create it (still simulation mode): powershell -File .\PHIDLP-Config.ps1 -PolicyName 'DLP - PHI Email - Simulation'` -Locations Exchange `-SensitiveTypes 'U.S. Social Security Number (SSN)','International Classification of Diseases (ICD-10-CM)'` -RequireAllTypes -MinCount 1 -Confidence Medium -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the

New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with PHIDLP-Validate.ps1 / PHIDLP-Discovery.ps1. .NOTES Purview — HIPAA / PHI DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. Which data is PHI and the enforced action per category are compliance/privacy/legal determinations — deferred. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Default set = HIPAA-relevant built-in SITs. Verify these names exist in your tenant (SIT library evolves). [string[]]$SensitiveTypes = @('U.S. Social Security Number (SSN)','International Classification of Diseases (ICD-10-CM)'), Require ALL supplied SITs to co-occur (PHI = identifier + clinical detector). Off = ANY-of (a match on one). [switch]$RequireAllTypes, [int]$MinCount = 1, [ValidateSet('Low','Medium','High')][string]$Confidence = 'Medium', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

PHIDLP-Discovery.ps1

Purpose: Builds the PHI DLP baseline: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and the locations it covers, plus whether the HIPAA-relevant built-in sensitive information types are present in the tenant (U.S. Social Security Number (SSN), International Classification of Diseases (ICD-9-CM), International Classification of Diseases (ICD-10-CM), Drug Enforcement Agency (DEA) Number) and a summary of custom SITs / EDM schemas. Read-only — makes no changes. Run it before building simulation policies. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PHIDLP-Discovery.ps1 -CsvPath .\PHIDLP-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations), a HIPAA-SIT presence checklist, and custom/EDM counts, plus an optional CSV of the policy inventory. PASS signal: policies you expect in simulation report a Test* mode; the HIPAA-relevant SITs you plan to use are present; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — HIPAA / PHI DLP Pack. Read-only against Security & Compliance PowerShell. No changes made. HIPAA breach determination is deferred to the Privacy/Security Officer — this tool only reports posture. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PHIDLP-Discovery.ps1 -CsvPath .\PHIDLP-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations), a HIPAA-SIT presence checklist, and custom/EDM counts, plus an optional CSV of the policy inventory. PASS signal: policies you expect in simulation report a Test* mode; the HIPAA-relevant SITs you plan to use are present; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — HIPAA / PHI DLP Pack. Read-only against Security & Compliance PowerShell. No changes made. HIPAA breach determination is deferred to the Privacy/Security Officer — this tool only reports posture. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

PHIDLP-Report.ps1

Purpose: Exports DLP rule matches (Exchange, SharePoint/OneDrive, Teams, and Endpoint) over a time window so you can classify true-positive vs false-positive and compute the false-positive rate that gates

simulation-to-enforcement for the PHI policies. Works for policies in simulation AND enforcement — simulation matches are logged the same way. Read-only — queries Search-UnifiedAuditLog only. Contains references to matched sensitive-info-type NAMES and message metadata; treat the output CSV as PHI-adjacent and store it under your own controls. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PHIDLP-Report.ps1 -Days 14 -CsvPath .\PHIDLP-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true PHI positives still present. .NOTES Purview — HIPAA / PHI DLP Pack. Read-only reporting from the unified audit log. No changes made. Output is PHI-adjacent evidence — retain per your records/compliance determination; do not over-share. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PHIDLP-Report.ps1 -Days 14 -CsvPath .\PHIDLP-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true PHI positives still present. .NOTES Purview — HIPAA / PHI DLP Pack. Read-only reporting from the unified audit log. No changes made. Output is PHI-adjacent evidence — retain per your records/compliance determination; do not over-share. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

PHIDLP-ScopeHealth.ps1

Purpose: Two jobs for the pilot phase. (1) HEALTH (read-only): reports Endpoint-DLP readiness signals — an E5/E5-Compliance licensing signal via Microsoft Graph and whether any DLP policy already uses the Endpoint (Devices) location — so you know the Devices location can function before you scope it. (2) SCOPE: reports a named PHI policy's locations, mode, and current member-of scope, and — only with -Commit — narrows an Exchange/OneDrive policy to a PILOT RING group so enforcement can be limited before tenant-wide expansion. Safe by default: -WhatIf reports only; writes require -Commit. This helper adjusts SCOPE only — it NEVER flips a policy to enforce (that is a deliberate portal/change-control action). HOW TO RUN Health + scope report only (no group supplied): powershell -File .\PHIDLP-ScopeHealth.ps1 -PolicyName 'DLP - PHI Email - Simulation' -WhatIf Restrict the Exchange policy to a pilot-ring group (still simulation mode): powershell -File .\PHIDLP-ScopeHealth.ps1 -PolicyName 'DLP - PHI Email - Simulation' ` -PilotRingGroup 'PHIDLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession); the licensing signal also uses Microsoft Graph (Organization.Read.All). EXPECTED RESULTS A readiness summary (licensing signal + endpoint-location usage) and the policy's current scope. -WhatIf: prints the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the member-of scope and re-prints it. PASS: endpoint capable/onboarded where needed; the policy's *MemberOf scope equals the pilot ring; Mode unchanged (still simulation until you enforce in the portal). .NOTES Purview — HIPAA / PHI DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [switch]$SkipHealth, [string]$UserPrincipalName, [switch]$Commit)

How to run: Health + scope report only (no group supplied): powershell -File .\PHIDLP-ScopeHealth.ps1 -PolicyName 'DLP - PHI Email - Simulation' -WhatIf Restrict the Exchange policy to a pilot-ring group (still

simulation mode): powershell -File .\PHIDLP-ScopeHealth.ps1 -PolicyName 'DLP - PHI Email - Simulation' ` -PilotRingGroup 'PHIDLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession); the licensing signal also uses Microsoft Graph (Organization.Read.All). EXPECTED RESULTS A readiness summary (licensing signal + endpoint-location usage) and the policy's current scope. -WhatIf: prints the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the member-of scope and re-prints it. PASS: endpoint capable/onboarded where needed; the policy's *MemberOf scope equals the pilot ring; Mode unchanged (still simulation until you enforce in the portal). .NOTES Purview — HIPAA / PHI DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [switch]$SkipHealth, [string]$UserPrincipalName, [switch]$Commit)

PHIDLP-Validate.ps1

Purpose: Confirms the implementation state before and after enforcement: for each expected PHI DLP policy it reports the MODE (simulation vs enforce vs disabled), whether the HIPAA-relevant sensitive information types are actually attached to the policy's rule(s), and the location scope. Use it as the gate check: during pilot build every policy should be in SIMULATION with the PHI SITs present; after Phase 4 the pilot policies should be ENFORCING and scoped to the ring. Read-only — no changes. HOW TO RUN Validate the three standard simulation policies: powershell -ExecutionPolicy Bypass -File .\PHIDLP-Validate.ps1 `-PolicyNames 'DLP - PHI Email - Simulation','DLP - PHI SPO+OneDrive+Teams - Simulation','DLP - PHI Endpoint - Simulation'` -ExpectMode Simulation Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A per-policy PASS/FAIL table: PASS = policy exists, its Mode matches -ExpectMode, and at least one expected HIPAA SIT is attached. FAIL/verify rows point at the missing piece (policy absent, wrong mode, or no PHI SIT attached). A non-zero exit code if any policy fails, for use in checks. .NOTES Purview — HIPAA / PHI DLP Pack. Read-only validation. No changes made. Confirms control state, not breach status. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - PHI Email - Simulation', 'DLP - PHI SPO+OneDrive+Teams - Simulation', 'DLP - PHI Endpoint - Simulation'), [ValidateSet('Simulation','Enforce','Any')][string]$ExpectMode = 'Simulation', Expected HIPAA-relevant SIT names — at least one must be attached to count as covered. [string[]]$ExpectedSits = @('U.S. Social Security Number (SSN)', 'International Classification of Diseases (ICD-9-CM)', 'International Classification of Diseases (ICD-10-CM)', 'Drug Enforcement Agency (DEA) Number', 'MRN - Custom SIT - PHI'), [string]$UserPrincipalName)

How to run: Validate the three standard simulation policies: powershell -ExecutionPolicy Bypass -File .\PHIDLP-Validate.ps1 `-PolicyNames 'DLP - PHI Email - Simulation','DLP - PHI SPO+OneDrive+Teams - Simulation','DLP - PHI Endpoint - Simulation'` -ExpectMode Simulation Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A per-policy PASS/FAIL table: PASS = policy exists, its Mode matches -ExpectMode, and at least one expected HIPAA SIT is attached. FAIL/verify rows point at the missing piece (policy absent, wrong mode, or no PHI SIT attached). A non-zero exit code if any policy fails, for use in checks. .NOTES Purview — HIPAA / PHI DLP Pack. Read-only validation. No changes made. Confirms control state, not breach status. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - PHI Email - Simulation', 'DLP - PHI SPO+OneDrive+Teams - Simulation', 'DLP - PHI Endpoint - Simulation'), [ValidateSet('Simulation','Enforce','Any')][string]$ExpectMode = 'Simulation', Expected HIPAA-relevant SIT names — at least one must be attached to count as covered. [string[]]$ExpectedSits = @('U.S. Social

```
Security Number (SSN)', 'International Classification of Diseases (ICD-9-CM)', 'International Classification of Diseases (ICD-10-CM)', 'Drug Enforcement Agency (DEA) Number', 'MRN - Custom SIT - PHI' ),
[string]$UserPrincipalName )
```